

TRIP FLY BD — Travel Agency ERP

System architecture and role-based access matrix — who can do what, in which module.

Generated from the live codebase: `backend/src/modules/*/*.routes.ts`, `middleware/rbac.ts`, `frontend/src/components/layout/AppShell.tsx`.

1 · Technology stack

Layer	Technology	Responsibility
Frontend	React 18 · TypeScript · Vite · TailwindCSS · Recharts	SPA on port 5173. Role-aware navigation hides what the user cannot reach.
Backend	Node.js · Express · TypeScript	REST API on port 4000. Clean architecture: routes → controllers → services → repositories.
Database	MySQL 8 (InnoDB, FK-enforced)	Single source of truth. All reports computed live from the voucher ledger.
Auth	JWT access + rotating refresh tokens	Access token short-lived; refresh rotates on every use. Role travels inside the JWT claim.
Authorization	Central <code>allow()</code> middleware	One RBAC gate applied per route. CEO bypasses every check as sole superuser.
Documents	pdfkit	Print-ready VAT invoices and payslips.

2 · Request flow

Every authenticated API call passes through the same five gates before it touches data. A request that fails any gate never reaches the database.

#	Gate	What it enforces
1	CORS + Helmet + rate limiter	Origin check, security headers, throttling. Login and refresh get a stricter limiter.
2	<code>authenticate</code>	Verifies the JWT, attaches <code>req.user = { sub, role, companyId }</code> .
3	<code>allow(...roles)</code>	The RBAC gate. CEO always passes; every other role must be listed explicitly on that route.
4	Zod schema validation	Request body parsed and typed before the controller runs. Malformed input rejected with 400.
5	Service + transaction	Business rules run inside a MySQL transaction. Debit must equal credit to the paisa or nothing commits.
6	<code>audit()</code>	Who did what, when, on which record — written after the transaction succeeds.

The one rule that shapes the whole matrix: CEO is the sole superuser. In `middleware/rbac.ts` the `allow()` helper returns early for CEO on every route, which is why CEO is never written into a route's role list — it would be redundant. Everyone else needs an explicit mention.

3 · The five roles

Role	Bootstrap login	Mandate
CEO	ceo@example.com	Sole superuser. Reaches every endpoint. Exclusively owns: company settings, user registration, payroll final approval, and the raw Database explorer.
ADMIN	admin@example.com	Operational oversight. Runs payroll day-to-day, manages master data, reads the books — but cannot post vouchers or create ledgers.
ACCOUNTANT	accountant@example.com	Owns the ledger. The only role that can post vouchers and create ledgers. Gets every statutory report. No access to HR or payroll.
SALES	sales@example.com	Front office. Creates bookings, customers, invoices, and collects money in. Cannot pay money out, cannot see the books.
HR	hr@example.com	People only. Employees and attendance. Deliberately has no payroll access at all — payroll sits with Admin and CEO to separate the person managing staff from the money paid to them.

4 · Navigation visibility

What each role actually sees in the sidebar. Hidden pages are hidden in the UI *and* blocked at the API — the frontend list mirrors the backend gate, it does not replace it.

● Full access ■ Partial / conditional ■ No access

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
Dashboard	●	●	●	●	●
Accounting	●	●	●	■	■
Invoices	●	●	●	●	■
Payments	●	●	●	■	■
Travel Bookings	●	●	●	●	■
Inventory	●	●	●	■	■
CRM	●	●	●	●	■
HR & Payroll	●	●	■	■	■
Reports	●	●	●	■	■
Database explorer	●	■	■	■	■
Settings	●	●	●	●	●

5 · Capability matrix by module

● Full access ■ Partial / conditional ■ No access

Accounting — the ledger core

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
View chart of accounts	●	●	●	●	●
View ledger groups	●	●	●	■	■
Create a ledger	●	■	●	■	■
Ledger statement	●	●	●	■	■
View vouchers	●	●	●	■	■
Post a voucher	●	■	●	■	■

Chart of accounts is readable by every authenticated role because the manual-invoice screen (reachable by Sales) needs it to fill the Income ledger dropdown. Posting vouchers stays with Accountant and CEO alone — vouchers are immutable, so a correction posts a mirrored reversal rather than an edit.

CRM — customers and suppliers

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
List customers / suppliers	●	●	●	●	●
Customer 360° profile	●	●	●	●	●
Create a customer	●	●	●	●	■
Create a supplier	●	●	●	■	■

Sales can onboard customers but not suppliers — a supplier record creates a payable sub-ledger, which is an accounting commitment. Every customer and supplier gets its own sub-ledger automatically, which is why these cannot be typed free-hand into an invoice.

Travel Bookings

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
View bookings / history	●	●	●	●	●
Create a booking	●	●	■	●	■
Confirm a booking	●	●	●	●	■
Cancel a booking	●	●	●	●	■

Confirming posts the sales voucher, raises the VAT invoice and books supplier cost in one transaction. Cancelling reverses both vouchers and voids the invoice — money already collected must be refunded first.

5 · Capability matrix by module (continued)

● Full access
■ Partial / conditional
■ No access

Invoices

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
View invoices	●	●	●	●	●
Download invoice PDF	●	●	●	●	●
Raise a manual invoice	●	●	●	●	■

Payments

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
View payments	●	●	●	●	■
Record money IN (collection)	●	●	●	●	■
Record money OUT (supplier payment / refund)	●	●	●	■	■

This is the sharpest split in the system. The route lets Sales through, then the controller rejects any payment where direction is not IN. Sales collects; only Accounts pays out or refunds.

Inventory

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
View items / warehouses / stock	●	●	●	●	●
Create an item	●	●	●	■	■
Create / edit / delete warehouse	●	●	●	■	■
Record stock movement	●	●	●	●	■
Valuation (FIFO / weighted avg)	●	●	●	●	●

Master data (items, warehouses) belongs to Accounts and Admin; the daily IN/OUT movement can be recorded by Sales too. This is why a Sales user sees an empty Item dropdown on a fresh database — the items must be created by an Accountant, Admin or CEO first.

HR & Payroll

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
Employees — view / create / edit	●	●	■	■	●
Attendance — view / mark	●	●	■	■	●
Payroll — view runs	●	●	■	■	■
Generate a payroll run	●	●	■	■	■
Approve a payroll run	●	■	■	■	■
Mark payroll paid	●	●	■	■	■
Payslip PDF	●	●	■	■	■

A deliberate separation of duties: HR manages people but never touches payroll money, Admin prepares and disburses the run, and only the CEO can approve it. The Accountant is kept out of HR entirely.

5 · Capability matrix by module (continued)

● Full access ■ Partial / conditional ■ No access

Reports

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
Trial Balance	●	■	●	■	■
Profit & Loss	●	■	●	■	■
Balance Sheet	●	■	●	■	■
Cash Book	●	●	●	■	■
Bank Book	●	●	●	■	■
Day Book	●	●	●	■	■
Daily Sales	●	●	●	●	■
Customer Outstanding	●	●	●	●	■

Report access is split by category rather than one blanket gate. The three statutory statements (Trial Balance, P&L, Balance Sheet) are Accountant and CEO only — not even Admin sees them. Sales gets the two commercial reports. HR gets none; its employee reports are served from the HR module directly.

System & administration

Capability	CEO	ADMIN	ACCOUNTANT	SALES	HR
Dashboard	●	●	●	●	●
View company settings	●	●	●	●	●
Edit company settings / logo	●	■	■	■	■
Register a new user	●	■	■	■	■
List users	●	●	■	■	■
Database explorer / export	●	■	■	■	■

Four capabilities are CEO-exclusive across the whole system: company identity, user creation, payroll approval, and raw database access including full JSON backup and per-table CSV export.

6 · CEO-exclusive powers

Everything else is delegated. These five are not:

Power	Endpoint	Why it is reserved
Company identity	PUT /api/company-settings	Name, VAT/BIN, logo — these print on every invoice and payslip.
User creation	POST /api/auth/register	Creating a user means granting a role. Role assignment stays at the top.
Payroll approval	POST /api/hr/payroll/:id/approve	Admin prepares the run and disburses it; the CEO signs off. Preparation and approval never sit in one pair of hands.
Database explorer	GET /api/admin/database/*	Raw table reads, CSV export, full JSON backup.
Universal bypass	every route	The <code>allow()</code> helper short-circuits for CEO, so no route can lock the CEO out.

7 · Setup order on a fresh database

The seed ships five user accounts and a default chart of accounts — no company, customers, suppliers, items or transactions. Dropdowns will read empty until the master data below exists, which is expected, not a fault. Each step must be done by a role that is allowed to do it:

#	Step	Who must do it
1	Company Setup Wizard — name, address, VAT/BIN, currency, logo	CEO only
2	Create the other users and assign roles	CEO only
3	Review / extend the chart of accounts	Accountant, CEO
4	Create suppliers	Accountant, Admin, CEO
5	Create customers	Sales, Accountant, Admin, CEO
6	Create inventory items and warehouses	Accountant, Admin, CEO
7	Create employees, then mark attendance	HR, Admin, CEO
8	Start trading — bookings, invoices, collections, stock movements	Sales, Accountant, Admin, CEO
9	Run payroll: generate → approve → pay	Admin generates & pays, CEO approves
10	Read the books — Trial Balance, P&L, Balance Sheet	Accountant, CEO

Why nothing can be typed free-hand. Customers, suppliers, items and ledgers all exist as records because each one carries its own sub-ledger in the books. An invoice raised against a name typed into a text box would have no ledger behind it — the receivable balance, the customer statement and the Balance Sheet would all silently disagree. The dropdown-only design is what keeps the ledger the single source of truth.

Source of truth for this document: `backend/src/middleware/rbac.ts`, `backend/src/constants/roles.ts`, every `backend/src/modules/*/*.routes.ts`, `backend/src/modules/payments/payments.controller.ts` (the Sales direction check), and `frontend/src/components/layout/AppShell.tsx` plus `frontend/src/pages/reports/Reports.tsx` for navigation visibility.